# FUNDHUB LLC

## INFORMATION SECURITY POLICY

Version 1.1 | Reviewed November 6, 2026 | Policy owner: Chris Stanbridge

### 1. PURPOSE AND SCOPE

Fundhub protects the confidentiality, integrity, and availability of its customer, employee, contractor, and bank-connection data. This policy applies to people and devices with access to Fundhub production code, hosting, databases, logs, Plaid, and other service providers. The owner reviews it at least quarterly and after a material change or security incident. The operational runbook is docs/sops/RUNBOOK.md.

### 2. ACCESS AND AUTHENTICATION

Each person uses an individual account and the least access needed for their role. The owner reviews privileged access quarterly and removes or changes access when duties change or a person leaves. Production-critical provider accounts require a second sign-in factor. Recovery codes are stored in the account owner's password manager, not in source or shared messages. Fundhub account creation and normal sign-in precede passkey setup. Client, affiliate and company bank connections require a separate server-verified passkey assertion before Plaid opens and before the connection is saved, plus explicit consent. Passkey registration alone is insufficient. Supported authenticators may use Face ID, fingerprint or their local unlock code; Fundhub does not receive biometric samples. Recovery requires a recent primary sign-in and an unused recovery code. Old access and codes remain valid until a replacement passkey is successfully verified; the replacement then needs a separate assertion. An access requirement is recorded as implemented only after the live setting and sign-in path are verified.

### 3. DATA AND SECRETS

Secrets belong in provider-managed environment settings, never in source control. Plaid access tokens are encrypted before database storage. Public production traffic uses HTTPS. Application database connections require TLS 1.2 or newer, trusted certificate and hostname verification; plaintext is limited to explicitly disposable local test databases. Data received from Plaid is stored in Fundhub's Supabase database, whose published policy covers database data and backups with AES-256. Identified downstream processors of Plaid-derived summaries (Twilio, Resend, Anthropic, Inngest, and Netlify logs) also publish encryption-at-rest commitments. Recipient mailboxes and phones are outside Fundhub's storage boundary. Access to consumer data is role scoped and logged where supported. Consent for bank linking records the exact text, scope, version, account, target, time and durable verified assertion reference, and is retained for review subject to an explicit erasure request.

### 4. CHANGE AND VULNERABILITY MANAGEMENT

Code changes receive automated lint, type checks where installed, focused tests, independent review for production-risk changes, and protected release checks. Production dependencies and assets are scanned on a recurring schedule. A finding is assigned an owner and due date; critical findings target repair within 7 days and high findings within 30 days, or sooner if a provider deadline applies. Due dates retain the original observation date instead of resetting on each scan. A fix is rescanned; a compensating control does not change an unpatched advisory into a passing dependency scan. Employee and contractor devices with production access belong in the scan inventory and require current protection. Missing device evidence is tracked as an open gap, not a completed control.

### 5. INCIDENT RESPONSE

The first responder records the time and affected system, limits exposure by suspending the credential or session, and preserves relevant logs. The owner determines affected data and people, rotates exposed keys, coordinates provider support, and records containment, recovery, notifications, and follow-up actions. Restore service through the tested release and backup procedures. The owner reviews the incident and updates controls. Availability incident steps and emergency contacts are in docs/sops/RUNBOOK.md.

## 6. RETENTION AND DELETION

Keep consumer data only while needed for the service and applicable obligations. Review each data class and retention period quarterly. A monthly job records count-only review receipts and does not delete customer records. Actual deletion requires signed retention periods, an owner/admin session with recently verified MFA, a dry-run review, and a durable receipt in the same transaction as the change. Deletion is manual until an approved schedule is implemented and verified. An individual erasure request follows the separate erasure procedure and preserves only records that must lawfully remain.

## 7. VENDORS AND EVIDENCE

The owner maintains a list of providers with access to sensitive data and reviews their access and security evidence. Control claims for Plaid or any other reviewer reflect observed production settings and retained test or provider receipts. Source code or this policy alone does not prove that a setting is active in production.

## IMPLEMENTATION STATUS AT REVIEW

This policy states required behavior; it is not an attestation that every control is deployed. The signed-in GitHub and Netlify operator accounts were verified with MFA enabled on November 6; this does not certify every critical provider or operator. A November 6 source revision implements bank-only passkey checks, scoped one-use challenges, recovery, explicit consent and heartbeat evidence, with real-signature and restricted-role PostgreSQL tests. Protected deployment and live user proof remain pending. New iOS and Mac development binaries have verified Fundhub team signatures and associated-domain entitlements for passkeys. Installation, distribution and physical-device user proof remain pending. A browser virtual authenticator test does not prove physical Face ID or fingerprint use. An external browser path is available for older iOS apps; older Mac users can open Fundhub directly in Safari or Chrome until updated.

The scheduled dependency scan ran on November 6 and reported two high and five moderate production dependency findings. Its GitHub Issue tracking step failed because Issues are disabled; a durable findings ledger repair is prepared and not yet deployed. Findings retain the earliest verified November 3 observation and an assigned owner. The unresolved advisories remain open; bounded signed Inngest request handling is a compensating control, not an SDK patch.

Default-company retention configuration and sign-offs were verified for six classes: credit raw payloads, SSN-access logs and soft-pull ledger: 762 days; bank transactions: 731 days; demo data: 7 days; broker uploads intentionally retained without a purge schedule. The recorded counsel-review condition is not independently proved complete. Monthly retention review is count-only; its first scheduled due date is December 1, not overdue in this review. A baseline production count and manual-review receipt remain pending. Full critical-provider MFA coverage, current access review, all-device scan inventory, backup and restore proof, recipient/export handling, retention coverage beyond these six classes and actual deletion evidence remain open. Local erasure does not yet establish remote Plaid Item removal.

Public fundhub.ai accepted TLS 1.2 and refused TLS 1.1 in the November 6 check. The revised application connection independently negotiated authorized TLS 1.3 to the Supabase pooler as fundhub_app in a read-only check; this is not yet deployed proof. The database reported no TLS on its managed pooler-to-database hop, so the client proof must not be described as encryption of every provider-internal hop. Update status from actual release and provider receipts before submitting questionnaire answers.

## PROVIDER EVIDENCE REVIEWED NOVEMBER 2, 2026

Supabase: https://supabase.com/legal/privacy-resources/data-residency-and-transfers-faq

Twilio: https://www.twilio.com/en-us/legal/security-overview

Resend: https://resend.com/security

Anthropic: https://trust.anthropic.com/faq

Inngest: https://www.inngest.com/docs/platform-and-operations/cloud-architecture-and-security

Netlify: https://docs.netlify.com/manage/security/overview/